



Ethical Hacking

Presented by: Zainab Mohamed

Email: zainab1234mo@gmail.com

LinkedIn: www.linkedin.com/in/zainab-suhaimi





TABLE OF CONTENTS



1

What is Hacking?

2

Who is a Hacker ?

3

What is Ethical Hacking?

4

5 Phases of hacking

4

Reconnaissance





What is Hacking?

Hacking is the process of identifying and exploiting weaknesses in a system or a network to gain unauthorized access to data and system resources.

It can also be defined as an unauthorized intrusion into the information systems/networks by an attacker by compromising the security.



+ Who is a Hacker ?

A person with excellent computer skills who can create and explore computer software and hardware.

For some hackers, hacking is a hobby, for another ones it is to gain knowledge or to do illegal things.



+

+

+

Hacker Classes

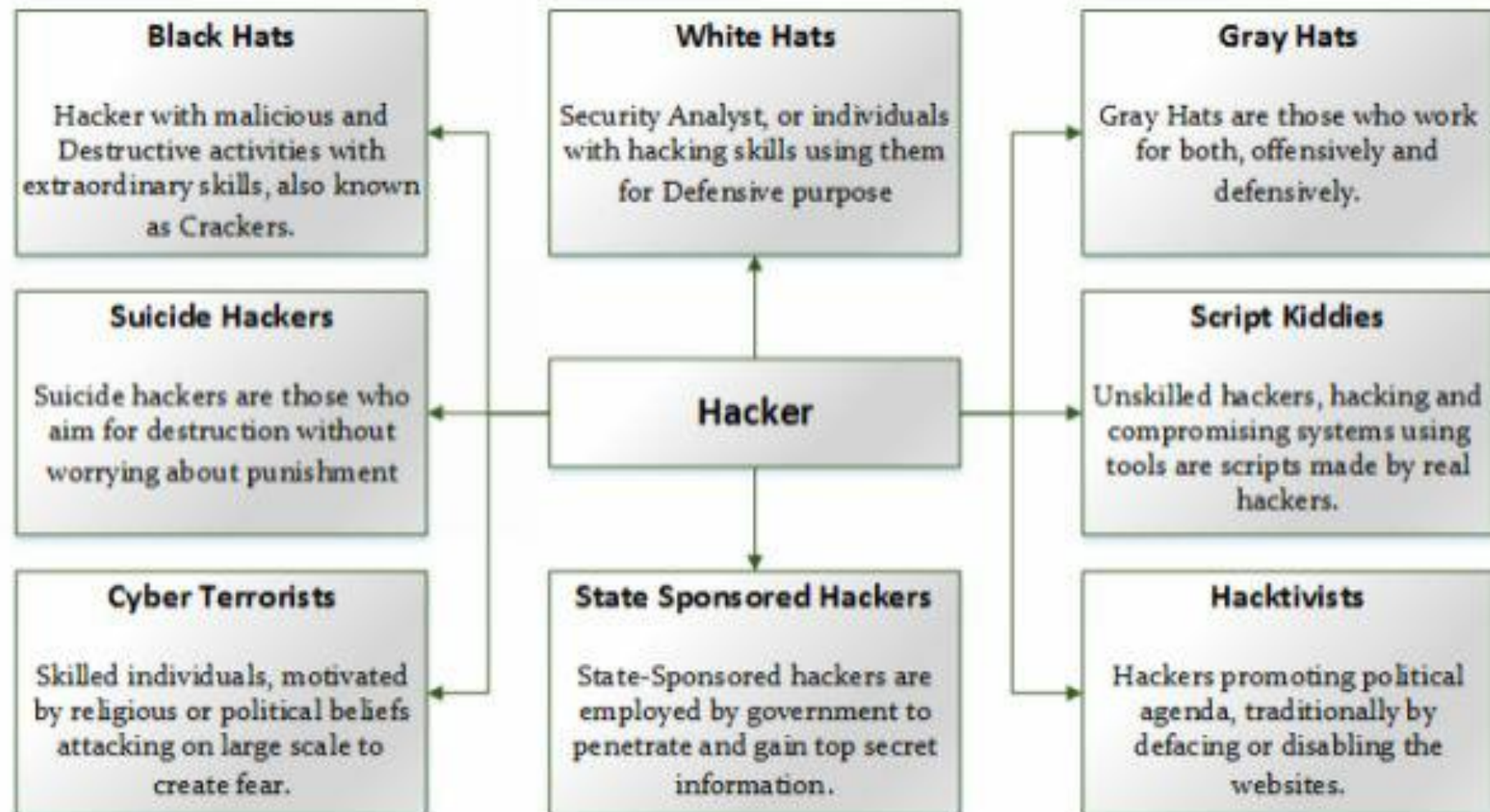
+

- **Black Hat**
- **White Hat**
- **Grey Hat**
- **Suicide Hackers**
- **Script Kiddies**
- **Financial Gain**
- **Trade Secrets and Global Politics**
- **Hacktivist**

+



+



1. Black Hat

Individuals who use their computing skills for illegal or malicious purposes. This category of hacker is often involved in criminal activities. They are also known as crackers.



2. White Hats

White hats or penetration testers are individuals who use their hacking skills for defensive purposes. They have the permission from the system owner.



3. Grey Hats

Individuals who work both offensively and defensively at various times.

They might help hackers to find various vulnerabilities in a system or network and, at the same time, help vendors to improve products (software or hardware) by checking limitations and making them more secure.



4. Suicide Hackers

Individuals who aim to bring down critical infrastructure for a cause and are not worried about facing jail terms or any other kind of punishment.

5. Script Kiddies

Amateurs, also known as script kiddies, have little or no skill. They often use existing tools or instructions found on the internet to launch attacks. Some are just curious, while others try to demonstrate their skills by causing harm. Even though they are using basic tools, the results can still be devastating.



6. Financial Gain

Much of the hacking activity that consistently threatens our security is motivated by financial gain. These cybercriminals want to gain access to our bank accounts, personal data, and anything else they can leverage to generate cash flow.



7. Trade Secrets and Global Politics

In the past several years, we have heard many stories about nation states hacking other countries, or otherwise interfering with internal politics. Nation states are also interested in using cyberspace for industrial espionage. The theft of intellectual property can give a country a significant advantage in international trade. Defending against the fallout from state-sponsored cyberespionage and cyberwarfare will continue to be a priority for cybersecurity professionals.



8. Hacktivists

Hacktivists are hackers who protest against a variety of political and social ideas. Hacktivists publicly protest against organizations or governments by posting articles and videos, leaking sensitive information, and disrupting web services with illegitimate traffic in distributed denial of service (DDoS) attacks.



Environmental Considerations

+

- 1 Network Infrastructure Tests
- 2 Application-Based Tests
- 3 Penetration Testing in the Cloud

+

+

Network Infrastructure Tests

Network infrastructure testing focuses on assessing the security of network components like switches, routers, firewalls, AAA servers, and IPSs. It may also include wireless testing, which involves identifying weaknesses by bypassing security measures or breaking encryption. Wireless assessments often provide a heat map showing signal coverage and potential exposure.

Application-Based Tests

This type of pen testing focuses on testing for security weaknesses in enterprise applications. These weaknesses can include but are not limited to misconfigurations, input validation issues, injection issues, and logic flaws. Because a web application is typically built on a web server with a back-end database, the testing scope normally includes the database as well. However, it focuses on gaining access to that supporting database through the web application compromise. A great resource that we mention a number of times in this book is the Open Web Application Security Project (OWASP).

Penetration Testing in the Cloud



- Cloud security is a shared responsibility between the provider and the customer, depending on the service model (IaaS, PaaS, SaaS). Customers must secure their data, applications, and systems, while providers handle the infrastructure.
- Security terms—like encryption, SLAs, and disaster recovery—must be clearly defined in contracts. Customers should ensure the provider offers strong physical, logical, and administrative security.
- Before performing penetration tests in the cloud, clients must follow the provider's guidelines and understand what is allowed.



+

Hacking Phases

+

Phase 1

Reconnaissance

Phase 2

Scanning

Phase 3

Gaining access

Phase 4

Maintaining Access

Phase 5

Covering Tracks

+

+



1. Reconnaissance (Information Gathering) :



- Information gathering is the first step of any penetration test and involves gathering or collecting information about an individual, company, website or system that you are targeting.
- One of the nuances of this phase is that there is no unnecessary information, everything you collect should be recorded/saved for future use.
- The more information you have on your target, the more successful you will be during the latter stages of a penetration test.



- Information gathering is typically broken down into two types:

- Passive & Active





Passive Reconnaissance



- Involves gathering as much information as possible without actively engaging with the target.
- For example:
 - Identifying IP addresses & DNS information.
 - Identifying domain names and domain ownership information.
 - Identifying email addresses and social media profiles.
 - Identifying web technologies being used on target sites.
 - Identifying subdomains.





Active Reconnaissance



- Involves gathering as much information as possible by actively engaging with the target system. (You will require authorization in order to perform active information gathering)
- For example:
 - Discovering open ports on target systems.
 - Learning about the internal infrastructure of a target network/organization.
 - Enumerating information from target systems.
 - telephone calls to the target's help desk or technical department.





2. Scanning



- Scanning can be considered a logical extension (and overlap) of active reconnaissance that helps attackers identify specific vulnerabilities.
 - Scanning refers to the pre-attack phase when the attacker scans the network for specific information based on information gathered during reconnaissance.
 - can include the use of dialers, port scanners, ping tools, and vulnerability scanners
-  ■ Attackers extract information such as live machines, port, port status, OS details, device type, and system uptime to launch attack.





3. Gaining Access (Exploitation)



- Gaining access refers to the point where the attacker obtains access to the operating system or applications on the target's system
- The attacker can escalate privileges to obtain complete control of the system. In this process, the target's connected intermediate systems are also compromised.





4. Maintaining Access



- The phase when the attacker tries to retain their ownership of the system
- Attackers may prevent the system from being owned by other attackers by securing their exclusive access with backdoors, rootkits, or trojans





5. Covering Tracks



- Refers to the activities carried out by an attacker to hide malicious acts
- The attacker's intentions include obtaining continuing access to the victim's system, remaining unnoticed and uncaught, and deleting evidence that might lead to their prosecution
- The attacker overwrites the server, system, and application logs to avoid suspicion

 ■ ANTI Forensics





What is Ethical Hacking?

The use of hacking tools, tricks, and techniques to identify vulnerabilities and ensure system security

The term “ethical hacker” refers to security professionals who employ their hacking skills for defensive purposes

Ethical hackers perform security assessments for an organization with the permission of concerned authorities.



Importance of Ethical Hacking

To beat a hacker, you need to think like one!



Essential Terminology



➤ Hack Value:

- The perceived worth of a target to a hacker. It reflects the appeal or interest a particular target holds due to its potential for exploitation or the challenge it presents.
- Ex) A hacker might find more hack value in breaking into a government database due to the sensitive information it holds compared to a small business website.





➤ Zero-Day Attack: +

- An attack that exploits a previously unknown vulnerability in software or  hardware for which no patch or fix is available. The term "zero-day" refers to the fact that developers have had zero days to address and patch the vulnerability.
- Ex) A zero-day attack might target a newly discovered vulnerability in a popular web browser, allowing hackers to execute arbitrary code on users' computers before the vendor can release a patch.

➤ Payload:

- The part of an exploit or malware that performs the malicious action, such as executing commands, stealing data, or installing additional malware.
 - Ex) In a phishing attack, the payload might be a malicious attachment that, when opened, installs a keylogger on the victim's computer to capture their passwords.
- 





1. Reconnaissance



- Refers to the process of collecting as much as information as possible about the target system to find ways to penetrate into the system. An Ethical hacker has to spend the majority of his time in profiling an organization, gathering information about the host, network and people related to the organization.
- helps to:
 - Know Security Posture
 - Reduce Attack Area
 - Identify vulnerabilities
 - Draw Network map



Objectives of Reconnaissance

- + ■ Network Reconnaissance:
 - This is the process of collecting information related to a target network. Information like Domain name, subdomains, network blocks, IP addresses of reachable systems, IDSes running, private websites, TCP & UDP services running, VPN points, networking protocols, ACL's, etc are collected.
- Collect System Information
 - The information related to the target system like user and group names, system banners, routing tables, SNMP information, system names etc are collected using various methods.





Collect Organization's information

- The information related to employee details, organization website, Location details, security policies implemented, the background of the organization may serve as an important piece of information for compromising the security of the target using direct or social engineering attacks.





Reconnaissance Methodology



Through :

- Search Engines,
- Advance Google Hacking Techniques,
- Social Networking Sites,
- Websites,
- Competitive Intelligence,
- WHOIS,
- DNS,
- Network,
- Social Engineering.





Reconnaissance Methodology



through Search Engines

This is a passive information gathering process where we gather information about the target from social media, search engines, various websites etc. Information gathered includes name, personal details, geographical location details, login pages, intranet portals etc. Even some target specific information like Operating system details, IP details, Netblock information, technologies behind web application etc. can be gathered by searching through search engines



Ex: collecting information from Google, Bing etc.





Google Hacking:



Google hacking refers to collecting information using **google dorks** (keywords) by constructing search queries which result in finding sensitive information details collected include compromised passwords, default credentials, competitor information, information related to a particular topic etc.

Ex: inurl: site: allintitle: etc.





Web Archives

Web Archives are used to take Snapshot of every Website on the internet so you Can Access Old Versions of Websites and Deleted Domains

<https://archive.org>





Business Information



<https://www.crunchbase.com/>

finding business information about private and public companies.

<https://haveibeenpwned.com/>

Checks if there is any Email leakage

<https://builtwith.com/> Wappalyzer

Identifying website technologies





Subdomain Enumeration



Manual:

using google dorks [site:*.target.com]

Tool:

Sublist3r <https://github.com/about3la/Sublist3r>

Ex: sublist3r -d google.com

Amass <https://github.com/owasp-amass/amass>

Ex: amass enum -brute -d google.com

Website:

crt.sh <https://crt.sh/>

Dev.internal.google.com





Whois

Hackers use the Whois website to obtain information about the domain name, email-id  and domain owner. It is a tool for Website Footprinting; that is, it enables a hacker to trace a website. WHOIS Lookup Result Analysis:

- Lookup Result shows complete domain profile, including
- Registrant information
- Registrant Organization
- Registrant Country
- Domain name server information
- IP Address
- IP location
- Domain Status
- IP history,
- Registrar history,

DNS Records

Domain Name System records that provide information about the domain's IP address and mail servers.

Tools :

Nslookup, dig

nslookup -type=A tryhackme.com 1.1.1.1

dig @1.1.1.1 tryhackme.com MX

Online tool: [DNSDumpster.com](https://dnshistory.org/)

Common DNS Record Types	
Record	Description
A	Address record (IPv4)
AAAA	Address record (IPv6)
CNAME	Canonical Name record
MX	Mail Exchanger record
NS	Nameserver record
PTR	Pointer record
SOA	Start of Authority record
SRV	Service Location record
TXT	Text record



Shodan.io



tries to connect to every device reachable online to build a search engine of connected “things” in contrast with a search engine for web pages. Once it gets a response, it collects all the information related to the service and saves it in the database to make it searchable.

we can learn several things related to our search, such as:

- IP address
- hosting company
- geographic location
- server type and version



[Shodan Search Engine](#)





Social Engineering:



You can understand the social engineering as an art of extracting sensitive information from peoples. Social Engineers keep themselves undetected, people are unaware and careless and share their valuable information. This information is related to the type of social engineering. In Information Security aspects, Footprinting through Social engineering gathers information such as: -

- Credit card information.
- Username & Passwords.
- Security devices & Technology information.
- Operating System information.
- Software information.
- Network information.
- IP address & name server's information.
- Use pyphiser





Recon Labs



Visit the Links Below and try to solve the Rooms.

Passive recon:

<https://tryhackme.com/room/passiverecon>

Active recon:

<https://tryhackme.com/room/activerecon>





Commands



python -m SimpleHTTPServer 9000

>> to create simple server





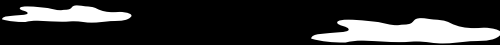
Task



- [TryHackMe | Linux Fundamentals Part 1](#)
- Passive recon
- Active recon
- [TryHackMe | DNS in Detail](#) optional

Screenshot for all rooms and upload on drive





THANK YOU

